

Manual 51 — Gobernanza, seguridad y responsabilidad humana para IA agéntica

Fuente controlada de publicación

Línea base de vigencia: 1 de septiembre de 2026

Regla de estado normativo: IMDA, NIST y OWASP se utilizan según su estado real; este manual no convierte orientación voluntaria, borradores, documentos conceptuales ni guías comunitarias en ley o certificación.

Propósito

Este manual establece un modelo práctico de gobernanza y seguridad para agentes de IA capaces de planificar, invocar herramientas, acceder a datos empresariales, mantener memoria, delegar en otros agentes y ejecutar acciones con consecuencias. El principio rector es gobernar la IA agéntica por las consecuencias de sus acciones, no solo por la calidad del texto generado.

Línea base de fuentes

- El Model AI Governance Framework for Agentic AI v1.0 de IMDA, publicado el 22 de enero de 2026, se trata como orientación gubernamental para facilitar la responsabilidad humana.
- NIST AI RMF 1.0 y NIST AI 600-1 continúan como orientación voluntaria de gestión de riesgos.
- El documento conceptual de NIST de febrero de 2026 sobre identidad y autorización de agentes de software e IA sigue siendo conceptual, no un estándar obligatorio final.
- La actualización pública de NIST de agosto de 2026 refuerza la importancia de identidades atribuibles, mínimo privilegio y autorización sólida.
- OWASP Top 10 for Agentic Applications 2026 y State of Agentic AI Security and Governance 2.01 se tratan como orientación comunitaria de seguridad.

Arquitectura de controles agénticos

AG-01 Identidad del agente

Todo agente de producción con acceso a recursos empresariales debe tener identidad atribuible, propietario responsable, propósito y entorno registrados.

AG-02 Autenticación y credenciales

Los agentes usan credenciales controladas; se evitan cuentas humanas compartidas, secretos incrustados y tokens de larga duración sin control compensatorio.

AG-03 Autorización y mínimo privilegio

Conceder solo herramientas, datos y acciones necesarias. La autorización debe aplicarse técnicamente y no depender únicamente de instrucciones en prompts.

AG-04 Límites de capacidad y autonomía

Documentar objetivos permitidos, acciones, herramientas, dominios de datos, límites transaccionales, comunicación externa, ejecución de código y actividades prohibidas.

AG-05 Puntos humanos significativos

Definir aprobación humana antes de acciones legales, financieras, de seguridad, empleo, control de acceso, comunicación externa o acciones irreversibles. El aprobador debe poder rechazar y el sistema debe impedir la ejecución tras el rechazo.

AG-06 Límites de confianza de herramientas, MCP y API

Tratar herramientas, servidores MCP, APIs, plugins y conectores como fronteras de seguridad con inventario, clasificación de confianza, validación de esquema, alcances y listas permitidas.

AG-07 Límites de datos y memoria

Controlar lectura, retención, recuperación, escritura y divulgación en memoria de sesión, memoria persistente, RAG y servicios externos.

AG-08 Integridad de instrucciones y prompts

Separar instrucciones confiables del contenido no confiable, mitigar prompt injection indirecto y validar argumentos antes de ejecutar herramientas.

AG-09 Procedencia de acciones

Toda acción material debe poder reconstruirse: solicitante/contexto, identidad y versión del agente, decisión de política, herramienta, aprobación o rechazo, resultado y efecto posterior.

AG-10 Delegación multiagente

Definir qué agentes pueden delegar, qué autoridad se transfiere y cómo se limitan memoria, credenciales y herramientas para evitar amplificación de privilegios.

AG-11 Terceros y proveedores

Evaluar modelos, agentes, plugins y herramientas externos respecto de datos, permisos, cambios, incidentes, continuidad, concentración y salida.

AG-12 Monitoreo y anomalías

Monitorear uso inusual de herramientas, cambios de privilegio, velocidad de acciones, rechazos de política, delegación inesperada, acceso sensible y efectos anómalos.

AG-13 Contención y capacidad de detención

Proveer y probar mecanismos para detener al agente, revocar credenciales, deshabilitar herramientas, aislar entornos y prevenir nuevas acciones dañinas.

AG-14 Respuesta a incidentes

Integrar incidentes agénticos al proceso empresarial, preservando instrucciones, identidades, trazas, llamadas a herramientas, aprobaciones, versiones y políticas.

AG-15 Cambios y revalidación

Cambios materiales de modelo, instrucciones, herramientas, permisos, autonomía, proveedor, datos, RAG, memoria, geografía o propósito requieren reevaluación y revalidación proporcional.

AG-16 Pruebas y evaluación adversarial

Probar uso no autorizado de herramientas, prompt injection, escalamiento de privilegios, manipulación entre agentes, fuga de datos, autonomía insegura, herramientas falsas, memoria contaminada y respuesta de contención.

AG-17 Competencia humana y sesgo de automatización

Las personas supervisoras deben comprender límites, evidencia y rutas de escalamiento y conservar criterio independiente cuando existe responsabilidad humana.

AG-18 Transparencia al usuario

Cuando corresponda, informar que existe interacción con un agente, su función, límites, acciones posibles y canales para impugnar o escalar problemas.

AG-19 Gobernanza y aceptación de riesgo

Desplegar, restringir, suspender o retirar capacidades agénticas según riesgo documentado, pruebas, riesgo residual y aprobación responsable.

AG-20 Auditabilidad y aseguramiento continuo

Conservar evidencia suficiente para comprobar periódicamente la efectividad de controles a medida que evolucionan modelos, herramientas, permisos y dependencias.

Clases de autonomía

- ****Clase A — solo observación:**** recomendaciones sin efecto externo.
- ****Clase B — acción reversible y acotada:**** autonomía dentro de límites técnicos y monitoreo continuo.
- ****Clase C — acción material:**** aprobación humana antes de ejecutar, salvo política de emergencia documentada.
- ****Clase D — acción irreversible o de alto impacto:**** doble control o aprobación responsable designada, con evidencia reforzada.

Modelo de evidencia

La evidencia mínima incluye inventario del agente; especificación de límites de acción; diseño de identidad y autorización; lista permitida de herramientas y datos; matriz de responsabilidad humana; procedencia de acciones; evaluación de seguridad; cambio/revalidación; monitoreo; prueba de contención; incidente; evaluación de terceros; excepciones y aseguramiento independiente.

Cadena mínima para acciones con consecuencias:

solicitante/contexto → identidad/versión del agente → evaluación de autorización/política → herramienta/acción solicitada → aprobación o rechazo → resultado de ejecución → efecto posterior → monitoreo o incidente

Escenarios prácticos

Agente de compras

Puede consultar proveedores aprobados y preparar solicitudes, pero la ejecución se limita por alcance. Umbrales de valor y proveedores no aprobados requieren autorización humana o rechazo técnico.

Cadena multiagente de publicación

Separar investigación, resumen, redacción y publicación. Cada delegación debe ser atribuible y la publicación externa debe estar detrás de una frontera controlada.

Cambio de herramienta de tercero

Cambios de versión disparan revisión de esquema, reevaluación del proveedor, regresión y revalidación antes de aceptar permisos o salidas ampliadas.

Exportación prohibida de datos

Una solicitud de enviar datos restringidos a un destino no aprobado debe bloquearse antes de la herramienta y conservar identidad, regla, clasificación, destino y resultado de investigación.

Remediación autónoma de seguridad

Observar puede ser autónomo; contención reversible puede ser acotada; revocaciones o aislamiento de alto impacto requieren aprobación más fuerte según impacto y política de emergencia.

Deriva de privilegios

Los cambios acumulativos de permisos se revisan como un delta consolidado. Combinaciones tóxicas y nueva autoridad de delegación disparan revalidación.

Regla de responsabilidad humana

La supervisión no se satisface por incluir una persona nominalmente. El punto de control es efectivo solo cuando la persona es identificable, competente, informada, autorizada para rechazar, dispone de contexto suficiente y puede detener técnicamente la acción antes del efecto relevante.

Uso entre marcos

IMDA aporta orientación de gobernanza; NIST aporta gestión de riesgo y consideraciones emergentes de identidad/autorización; OWASP aporta amenazas y mitigaciones prácticas. Pueden apoyar un mismo control empresarial sin ser equivalentes. Ningún mapeo puede afirmar que adoptar una fuente demuestra cumplimiento de otra.

Puerta de despliegue

Antes de producción confirmar: propósito y propietario; inventario; clase de autonomía; identidad; mínimo privilegio; límites de herramientas y datos; puntos humanos; procedencia; pruebas adversariales; prueba de contención; revisión de terceros; monitoreo; respuesta a incidentes; disparadores de revalidación; decisión de riesgo residual; y retención de evidencia.

Criterio final de publicación

El manual está listo cuando AG-01 a AG-20 aparecen en las fuentes controladas trilingües, se generan seis artefactos DOCX/PDF, pasan las pruebas de texto visible y renderizado, se congelan hashes y tamaños exactos, se reconcilian los registros de publicación, la seguridad de workflows permanece limpia, el Manual 50 está publicado y no existe defecto sustantivo o técnico sin resolver.